



Courier Management System Low Privilege

Report generated by Tenable Nessus™

Mon, 27 Apr 2026 22:39:00 +08

TABLE OF CONTENTS

Vulnerabilities by Plugin

• 122584 (1) - SQLi scanner.....	5
• 40984 (1) - Browsable Web Directories.....	6
• 65702 (1) - Git Repository Served by Web Server.....	8
• 85582 (1) - Web Application Potentially Vulnerable to Clickjacking.....	9
• 136929 (1) - JQuery 1.2 < 3.5.0 Multiple XSS.....	11
• 26194 (1) - Web Server Transmits Cleartext Credentials.....	13
• 42057 (1) - Web Server Allows Password Auto-Completion.....	15
• 11219 (2) - Nessus SYN scanner.....	16
• 10107 (1) - HTTP Server Type and Version.....	17
• 10662 (1) - Web mirroring.....	18
• 11419 (1) - Web Server Office File Inventory.....	20
• 19506 (1) - Nessus Scan Information.....	21
• 24260 (1) - HyperText Transfer Protocol (HTTP) Information.....	23
• 33817 (1) - CGI Generic Tests Load Estimation (all tests).....	25
• 39470 (1) - CGI Generic Tests Timeout.....	27
• 40773 (1) - Web Application Potentially Sensitive CGI Parameter Detection.....	28
• 43111 (1) - HTTP Methods Allowed (per directory).....	29
• 48204 (1) - Apache HTTP Server Version.....	31
• 49704 (1) - External URLs.....	32
• 50344 (1) - Missing or Permissive Content-Security-Policy frame-ancestors HTTP Response Header.....	34
• 50345 (1) - Missing or Permissive X-Frame-Options HTTP Response Header.....	36
• 66334 (1) - Patch Report.....	38
• 72771 (1) - Web Accessible Backups.....	39
• 85601 (1) - Web Application Cookies Not Marked HttpOnly.....	40
• 85602 (1) - Web Application Cookies Not Marked Secure.....	42
• 91815 (1) - Web Application Sitemap.....	44
• 106658 (1) - JQuery Detection.....	46

• 156439 (1) - jQuery UI Detection.....	47
---	----

Vulnerabilities by Plugin

122584 (1) - SQLi scanner

Synopsis

The remote host is vulnerable to SQL injection.

Description

The scanner was able to send specially crafted input to one or more endpoints and parameters on the remote host that resulted in an injection into a SQL query, allowing arbitrary SQL statements to be executed on the remote host.

Solution

In the case of a third party product, the vendor should be notified of this vulnerability. In the case of a custom web application, the application should be updated to use parameterized queries, which prevent an attacker from being able to inject special characters that can be used to break out of the intended context and execute SQL statements.

Risk Factor

High

CVSS v3.0 Base Score

8.3 (CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:C/C:L/I:L/A:L)

CVSS v2.0 Base Score

7.5 (CVSS2#AV:N/AC:L/Au:N/C:P/I:P/A:P)

Plugin Information

Published: 2019/03/04, Modified: 2026/03/23

Plugin Output

192.168.100.50 (tcp/80/www)

```
Injection found on /admin/getbill.php in the following parameters :
customer_id
```

```
Injection was verified with "SELECT @@version" which yielded :
8.0.45-0ubuntu0.24004.1
```

40984 (1) - Browsable Web Directories

Synopsis

Some directories on the remote web server are browsable.

Description

Multiple Nessus plugins identified directories on the web server that are browsable.

See Also

<http://www.nessus.org/u?0a35179e>

Solution

Make sure that browsable directories do not leak confidential information or give access to sensitive resources. Additionally, use access restrictions or disable directory indexing for any that do.

Risk Factor

Medium

CVSS v3.0 Base Score

5.3 (CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)

CVSS v2.0 Base Score

5.0 (CVSS2#AV:N/AC:L/Au:N/C:P/I:N/A:N)

Plugin Information

Published: 2009/09/15, Modified: 2021/01/19

Plugin Output

192.168.100.50 (tcp/80/www)

The following directories are browsable :

```
http://192.168.100.50/Admin/assets/  
http://192.168.100.50/Admin/assets/css/  
http://192.168.100.50/Admin/assets/css/pages/  
http://192.168.100.50/Admin/assets/css/widgets/  
http://192.168.100.50/Admin/assets/images/  
http://192.168.100.50/Admin/assets/images/logo/  
http://192.168.100.50/Admin/assets/js/  
http://192.168.100.50/Admin/assets/js/extensions/  
http://192.168.100.50/Admin/assets/js/include/
```

<http://192.168.100.50/Admin/assets/js/pages/>
<http://192.168.100.50/Admin/assets/plugin/>
<http://192.168.100.50/Admin/assets/plugin/iziToast-master/>
<http://192.168.100.50/Admin/assets/plugin/iziToast-master/dist/>
<http://192.168.100.50/Admin/assets/plugin/iziToast-master/src/>
<http://192.168.100.50/Admin/assets/plugin/iziToast-master/types/>
<http://192.168.100.50/Admin/assets/plugin/pdf/>
<http://192.168.100.50/Admin/assets/plugin/pdf/font/>
<http://192.168.100.50/Admin/assets/plugin/pdf/makefont/>
<http://192.168.100.50/Admin/assets/vendors/>
<http://192.168.100.50/Admin/assets/vendors/apexcharts/>
<http://192.168.100.50/Admin/assets/vendors/apexcharts/locales/>
<http://192.168.100.50/Admin/assets/vendors/chartjs/>
<http://192.168.100.50/Admin/assets/vendors/choices.js/>
<http://192.168.100.50/Admin/assets/vendors/ckeditor/>
<http://192.168.100.50/Admin/assets/vendors/dayjs/>
<http://192.168.100.50/Admin/assets/vendors/dragula/>
<http://192.168.100.50/Admin/assets/vendors/dripicons/>
<http://192.168.100.50/Admin/assets/vendors/dripicons/fonts/>
<http://192.168.100.50/Admin/assets/vendors/dripicons/img/>
<http://192.168.100.50/Admin/assets/vendors/fontawesome/>
<http://192.168.100.50/Admin/assets/vendors/iconly/>
<http://192.168.100.50/Admin/assets/vendors/iconly/fonts/>
<http://192.168.100.50/Admin/assets/vendors/jquery/>
<http://192.168.100.50/Admin/assets/vendors/perfect-scrollbar/>
<http://192.168.100.50/Admin/assets/vendors/quill/>
<http://192.168.100.50/Admin/assets/vendors/rater.js/>
<http://192.168.100.50/Admin/assets/vendors/simple-datatables/>
<http://192.168.100.50/Admin/assets/vendors/summernote/>
[http://192.168.100.50 \[...\]](http://192.168.100.50)

65702 (1) - Git Repository Served by Web Server

Synopsis

The remote web server may disclose information due to a configuration weakness.

Description

The web server on the remote host allows read access to a Git repository. This potential flaw can be used to download content from the Web server that might otherwise be private.

See Also

<https://blog.skullsecurity.org/2012/using-git-clone-to-get-pwn3d>

<http://www.nessus.org/u?b573eafc>

Solution

Verify that the listed Git repositories are served intentionally.

Risk Factor

Medium

CVSS v2.0 Base Score

5.0 (CVSS2#AV:N/AC:L/Au:N/C:P/I:N/A:N)

Plugin Information

Published: 2013/03/27, Modified: 2021/01/19

Plugin Output

192.168.100.50 (tcp/80/www)

The following repositories were found on the remote web server :

```
Repository : http://192.168.100.50/.git
Type       : Non-Bare
Transport  : Not configured for cloning
```


85582 (1) - Web Application Potentially Vulnerable to Clickjacking

Synopsis

The remote web server may fail to mitigate a class of web application vulnerabilities.

Description

The remote web server does not set an X-Frame-Options response header or a Content-Security-Policy 'frame-ancestors' response header in all content responses. This could potentially expose the site to a clickjacking or UI redress attack, in which an attacker can trick a user into clicking an area of the vulnerable page that is different than what the user perceives the page to be. This can result in a user performing fraudulent or malicious transactions.

X-Frame-Options has been proposed by Microsoft as a way to mitigate clickjacking attacks and is currently supported by all major browser vendors.

Content-Security-Policy (CSP) has been proposed by the W3C Web Application Security Working Group, with increasing support among all major browser vendors, as a way to mitigate clickjacking and other attacks. The 'frame-ancestors' policy directive restricts which sources can embed the protected resource.

Note that while the X-Frame-Options and Content-Security-Policy response headers are not the only mitigations for clickjacking, they are currently the most reliable methods that can be detected through automation. Therefore, this plugin may produce false positives if other mitigation strategies (e.g., frame-busting JavaScript) are deployed or if the page does not perform any security-sensitive transactions.

See Also

<http://www.nessus.org/u?399b1f56>

https://www.owasp.org/index.php/Clickjacking_Defense_Cheat_Sheet

<https://en.wikipedia.org/wiki/Clickjacking>

Solution

Return the X-Frame-Options or Content-Security-Policy (with the 'frame-ancestors' directive) HTTP header with the page's response.

This prevents the page's content from being rendered by another site when using the frame or iframe HTML tags.

Risk Factor

Medium

CVSS v2.0 Base Score

4.3 (CVSS2#AV:N/AC:M/Au:N/C:N/I:P/A:N)

References

Plugin Information

Published: 2015/08/22, Modified: 2017/05/16

Plugin Output

192.168.100.50 (tcp/80/www)

The following pages do not use a clickjacking mitigation response header and contain a clickable event :

- <http://192.168.100.50/>
- <http://192.168.100.50/Admin/login.php>
- <http://192.168.100.50/Admin/register.php>
- http://192.168.100.50/change_email.php
- http://192.168.100.50/change_password.php
- <http://192.168.100.50/fonts/flaticon/font/flaticon.html>
- <http://192.168.100.50/index.php>
- <http://192.168.100.50/profile.php>
- <http://192.168.100.50/request.php>

136929 (1) - JQuery 1.2 < 3.5.0 Multiple XSS

Synopsis

The remote web server is affected by multiple cross site scripting vulnerability.

Description

According to the self-reported version in the script, the version of JQuery hosted on the remote web server is greater than or equal to 1.2 and prior to 3.5.0. It is, therefore, affected by multiple cross site scripting vulnerabilities.

Note, the vulnerabilities referenced in this plugin have no security impact on PAN-OS, and/or the scenarios required for successful exploitation do not exist on devices running a PAN-OS release.

See Also

<https://blog.jquery.com/2020/04/10/jquery-3-5-0-released/>

<https://security.paloaltonetworks.com/PAN-SA-2020-0007>

Solution

Upgrade to JQuery version 3.5.0 or later.

Risk Factor

Medium

CVSS v3.0 Base Score

6.1 (CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N)

CVSS v3.0 Temporal Score

5.7 (CVSS:3.0/E:F/RL:O/RC:C)

EPSS Score

0.5545

CVSS v2.0 Base Score

4.3 (CVSS2#AV:N/AC:M/Au:N/C:N/I:P/A:N)

CVSS v2.0 Temporal Score

3.6 (CVSS2#E:F/RL:OF/RC:C)

STIG Severity

II

References

CVE	CVE-2020-11022
CVE	CVE-2020-11023
XREF	IAVB:2020-B-0030
XREF	CEA-ID:CEA-2021-0004
XREF	CEA-ID:CEA-2021-0025
XREF	CISA-KNOWN-EXPLOITED:2025/02/13

Plugin Information

Published: 2020/05/28, Modified: 2025/01/24

Plugin Output

192.168.100.50 (tcp/80/www)

```
URL           : http://192.168.100.50/js/jquery-3.3.1.min.js
Installed version : 3.3.1
Fixed version  : 3.5.0
```

26194 (1) - Web Server Transmits Cleartext Credentials

Synopsis

The remote web server might transmit credentials in cleartext.

Description

The remote web server contains several HTML form fields containing an input of type 'password' which transmit their information to a remote web server in cleartext.

An attacker eavesdropping the traffic between web browser and server may obtain logins and passwords of valid users.

Solution

Make sure that every sensitive form transmits content over HTTPS.

Risk Factor

Low

CVSS v2.0 Base Score

2.6 (CVSS2#AV:N/AC:H/Au:N/C:P/I:N/A:N)

References

XREF	CWE:522
XREF	CWE:523
XREF	CWE:718
XREF	CWE:724
XREF	CWE:928
XREF	CWE:930

Plugin Information

Published: 2007/09/28, Modified: 2016/11/29

Plugin Output

192.168.100.50 (tcp/80/www)

```
Page : /change_password.php
Destination Page: /change_password.php

Page : /Admin/login.php
Destination Page: /Admin/login.php
```

Page : /Admin/register.php
Destination Page: /Admin/register.php

42057 (1) - Web Server Allows Password Auto-Completion

Synopsis

The 'autocomplete' attribute is not disabled on password fields.

Description

The remote web server contains at least one HTML form field that has an input of type 'password' where 'autocomplete' is not set to 'off'.

While this does not represent a risk to this web server per se, it does mean that users who use the affected forms may have their credentials saved in their browsers, which could in turn lead to a loss of confidentiality if any of them use a shared host or if their machine is compromised at some point.

Solution

Add the attribute 'autocomplete=off' to these fields to prevent browsers from caching credentials.

Risk Factor

Low

Plugin Information

Published: 2009/10/07, Modified: 2025/11/26

Plugin Output

192.168.100.50 (tcp/80/www)

```
Page : /change_password.php
Destination Page: /change_password.php

Page : /Admin/login.php
Destination Page: /Admin/login.php

Page : /Admin/register.php
Destination Page: /Admin/register.php
```

11219 (2) - Nessus SYN scanner

Synopsis

It is possible to determine which TCP ports are open.

Description

This plugin is a SYN 'half-open' port scanner. It shall be reasonably quick even against a firewalled target.

Note that SYN scans are less intrusive than TCP (full connect) scans against broken services, but they might cause problems for less robust firewalls and also leave unclosed connections on the remote target, if the network is loaded.

Solution

Protect your target with an IP filter.

Risk Factor

None

Plugin Information

Published: 2009/02/04, Modified: 2025/07/14

Plugin Output

192.168.100.50 (tcp/22/ssh)

```
Port 22/tcp was found to be open
```

192.168.100.50 (tcp/80/www)

```
Port 80/tcp was found to be open
```


10107 (1) - HTTP Server Type and Version

Synopsis

A web server is running on the remote host.

Description

This plugin attempts to determine the type and the version of the remote web server.

Solution

n/a

Risk Factor

None

References

XREF IAVT:0001-T-0931

Plugin Information

Published: 2000/01/04, Modified: 2020/10/30

Plugin Output

192.168.100.50 (tcp/80/www)

```
The remote web server type is :  
Apache/2.4.58 (Ubuntu)
```

10662 (1) - Web mirroring

Synopsis

Nessus can crawl the remote website.

Description

This plugin makes a mirror of the remote website(s) and extracts the list of CGIs that are used by the remote host.

It is suggested that you change the number of pages to mirror in the 'Options' section of the client.

Solution

n/a

Risk Factor

None

Plugin Information

Published: 2001/05/04, Modified: 2026/03/23

Plugin Output

192.168.100.50 (tcp/80/www)

```
Webmirror performed 617 queries in 41s (15.048 queries per second)
```

```
The following CGIs have been discovered :
```

```
+ CGI : /
  Methods : POST
  Argument : email
  Argument : message
  Argument : name
  Argument : subject

+ CGI : /index.php
  Methods : POST
  Argument : email
  Argument : message
  Argument : name
  Argument : subject

+ CGI : /admin/getbill.php
  Methods : GET
  Argument : customer_id
  Value: 12
```

```
+ CGI : /request.php
Methods : POST
Argument : customer_id
Value: 12
Argument : end_location
Value: 29
Argument : red_address
Argument : res_name
Argument : res_phone
Argument : send_location
Value: 29
Argument : sender_phone
Argument : total
Argument : total_fee
Argument : weight

+ CGI : /change_email.php
Methods : POST
Argument : current_email
Argument : customer_id
Value: 12
Argument : new_email

+ CGI : /change_password.php
Methods : POST
Argument : confirm_new_password
Argument : current_password
Argument : customer_id
Value: 12
Argument : new_password

+ CGI : /Admin/login.php
Methods : POST
Argument : email
Argument : password

+ CGI : /Admin/register.php
Methods :
Argument : address
Argument : conf_password
Argument : email
Argument : gender
Value: 0
Argument : name
Argument : nic
Argument : password
Argument : phone

Directory index found at /fonts/icomoon/
Directory index found at /fonts/
Directory index found at /css/
Directory index found at /fonts/flaticon/font/
Directory index found at /fonts/flaticon/
Directory index found at /fonts/icomoon/demo-files/
Directory index found at /fonts/icomoon/fonts/
Directory index found at /fonts/flaticon/license/
Directory index found at /Admin/assets/css/
Directory index found at /Admin/assets/
Directory index found at /Admin/assets/vendors/iconly/
Directory index found at /Admin/assets/vendors/
Directory index found at /Admin/assets/vendors/perfect-scrollbar/
Directory index found at /Admin/assets/images/
Directory index found at /Admin/assets/css/pages/
Directory [...]
```

11419 (1) - Web Server Office File Inventory

Synopsis

The remote web server hosts office-related files.

Description

This plugin connects to the remote web server and attempts to find office-related files such as .doc, .ppt, .xls, .pdf etc.

Solution

Make sure that such files do not contain any confidential or otherwise sensitive information and that they are only accessible to those with valid credentials.

Risk Factor

None

Plugin Information

Published: 2003/03/19, Modified: 2026/04/22

Plugin Output

192.168.100.50 (tcp/80/www)

The following office-related files are available on the remote server :

- Adobe Acrobat files (.pdf) :
/fonts/flaticon/license/license.pdf

19506 (1) - Nessus Scan Information

Synopsis

This plugin displays information about the Nessus scan.

Description

This plugin displays, for each tested host, information about the scan itself :

- The version of the plugin set.
- The type of scanner (Nessus or Nessus Home).
- The version of the Nessus Engine.
- The port scanner(s) used.
- The port range scanned.
- The ping round trip time
- Whether credentialed or third-party patch management checks are possible.
- Whether the display of superseded patches is enabled
- The date of the scan.
- The duration of the scan.
- The number of hosts scanned in parallel.
- The number of checks done in parallel.

Solution

n/a

Risk Factor

None

Plugin Information

Published: 2005/08/26, Modified: 2026/03/04

Plugin Output

192.168.100.50 (tcp/0)

Information about this scan :

```
Nessus version : 10.11.3
Nessus build : 20047
Plugin feed version : 202604262128
Scanner edition used : Nessus
Scanner OS : LINUX
Scanner distribution : debian10-x86-64
Scan type : Normal
```

Scan name : Courier Management System Low Privilege
Scan policy used : Web Application Tests
Scanner IP : 192.168.21.128
Port scanner(s) : nessus_syn_scanner
Port range : default
Ping RTT : 24.889 ms
Thorough tests : yes
Experimental tests : no
Scan for Unpatched Vulnerabilities : no
Plugin debugging enabled : no
Paranoia level : 1
Report verbosity : 2
Safe checks : yes
Optimize the test : yes
Credentialed checks : no
Patch management checks : None
Display superseded patches : yes (supersedence plugin did not launch)
CGI scanning : enabled
Web application tests : enabled
Web app tests - Test mode : all_pairs
Web app tests - Try all HTTP methods : yes
Web app tests - Maximum run time : 10 minutes.
Web app tests - Stop at first flaw : param
Max hosts : 30
Max checks : 4
Recv timeout : 5
Backports : Detected
Allow post-scan editing : Yes
Nessus Plugin Signature Checking : Enabled
Audit File Signature Checking : Disabled
Scan Start Date : 2026/4/27 21:46 +08 (UTC +08:00)
Scan duration : 3116 sec
Scan for malware : no
Fully Scan Operational Technology devices : yes
Safely Scan Operational Technology devices with OT Discovery : no

24260 (1) - HyperText Transfer Protocol (HTTP) Information

Synopsis

Some information about the remote HTTP configuration can be extracted.

Description

This test gives some information about the remote HTTP protocol - the version used, whether HTTP Keep-Alive is enabled, etc...

This test is informational only and does not denote any security problem.

Solution

n/a

Risk Factor

None

Plugin Information

Published: 2007/01/30, Modified: 2024/02/26

Plugin Output

192.168.100.50 (tcp/80/www)

Response Code : HTTP/1.1 200 OK

Protocol version : HTTP/1.1

HTTP/2 TLS Support: No

HTTP/2 Cleartext Support: No

SSL : no

Keep-Alive : yes

Options allowed : (Not implemented)

Headers :

Date: Mon, 27 Apr 2026 13:52:30 GMT

Server: Apache/2.4.58 (Ubuntu)

Expires: Thu, 19 Nov 1981 08:52:00 GMT

Cache-Control: no-store, no-cache, must-revalidate

Pragma: no-cache

Vary: Accept-Encoding

Keep-Alive: timeout=5, max=98

Connection: Keep-Alive

Transfer-Encoding: chunked

Content-Type: text/html; charset=UTF-8

Response Body :

<!DOCTYPE html>

<html lang="en">

<head>

```

<link rel="preconnect" href="https://fonts.googleapis.com">
<link rel="preconnect" href="https://fonts.gstatic.com" crossorigin>
<link href="https://fonts.googleapis.com/css2?family=Rubik:wght@300&display=swap" rel="stylesheet">
<link href="https://fonts.googleapis.com/css2?family=Josefin+Sans&display=swap" rel="stylesheet">

<!-- toast -->
<script src="admin/assets/plugin/iziToast-master/dist/js/iziToast.min.js" type="text/javascript"></script>
<link rel="stylesheet" href="admin/assets/plugin/iziToast-master/dist/css/iziToast.min.css">
<!-- endbuild -->

<script src="https://code.jquery.com/jquery-3.6.0.min.js" integrity="sha256-/xUj+3O/U5yExlq6GSYGSHk7tPXikynS7ogEvDej/m4=" crossorigin="anonymous"></script>

<!-- Simple table -->
<link href="https://cdn.jsdelivr.net/npm/simple-datatables@latest/dist/style.css" rel="stylesheet" />

<script src="https://kit.fontawesome.com/6e8b05f9c5.js" crossorigin="anonymous"></script>
<script src="https://use.fontawesome.com/releases/v6.1.0/js/all.js" crossorigin="anonymous"></script>

<script src="admin/assets/js/include/alerts.js"></script>
<script src="admin/assets/js/include/validation.js"></script>
<script src="admin/assets/js/include/homejs.js"></script>
<script src="admin/assets/js/include/upload.js"></script>
<script src="admin/assets/js/include/add.js"></script>
<script src="admin/assets/js/include/delete.js"></script>

<script src="admin/assets/js/include/main.js"></script>

<script src="https://c [...]
```


33817 (1) - CGI Generic Tests Load Estimation (all tests)

Synopsis

Load estimation for web application tests.

Description

This script computes the maximum number of requests that would be done by the generic web tests, depending on miscellaneous options. It does not perform any test by itself.

The results can be used to estimate the duration of these tests, or the complexity of additional manual tests.

Note that the script does not try to compute this duration based on external factors such as the network and web servers loads.

Solution

n/a

Risk Factor

None

Plugin Information

Published: 2009/10/26, Modified: 2022/04/11

Plugin Output

192.168.100.50 (tcp/80/www)

```
Here are the estimated number of requests in miscellaneous modes
for one method only (GET or POST) :
[Single / Some Pairs / All Pairs / Some Combinations / All Combinations]

arbitrary command execution (time based) : S=216          SP=216          AP=1272          SC=6
AC=23622
format string : S=72          SP=72          AP=424          SC=2
AC=7874
cross-site scripting (comprehensive test): S=612          SP=612          AP=3604          SC=17
AC=66929
injectable parameter : S=72          SP=72          AP=424          SC=2
AC=7874
arbitrary command execution : S=792          SP=792          AP=4664          SC=22
AC=86614
local file inclusion : S=144          SP=144          AP=848          SC=4
AC=15748
directory traversal : S=1044         SP=1044         AP=6148          SC=29
AC=114173
web code injection : S=36          SP=36          AP=212          SC=1
AC=3937
blind SQL injection (4 requests) : S=144          SP=144          AP=848          SC=4
AC=15748
```

persistent XSS AC=15748	: S=144	SP=144	AP=848	SC=4
directory traversal (write access) AC=7874	: S=72	SP=72	AP=424	SC=2
XML injection AC=3937	: S=36	SP=36	AP=212	SC=1
blind SQL injection AC=47244	: S=432	SP=432	AP=2544	SC=12
SQL injection AC=110236	: S=1008	SP=1008	AP=5936	SC=28
directory traversal (extended test) AC=200787	: S=1836	SP=1836	AP=10812	SC=51
SSI injection AC=11811	: S=108	SP=108	AP=636	SC=3
unseen parameters AC=137795	: S=1260	SP=1260	AP=7420	SC=35
SQL injection (2nd order)	[...]			

39470 (1) - CGI Generic Tests Timeout

Synopsis

Some generic CGI attacks ran out of time.

Description

Some generic CGI tests ran out of time during the scan. The results may be incomplete.

Solution

Consider increasing the 'maximum run time (minutes)' preference for the 'Web Applications Settings' in order to prevent the CGI scanning from timing out. Less ambitious options could also be used, such as :

- Test more than one parameter at a time per form :

'Test all combinations of parameters' is much slower than 'Test random pairs of parameters' or 'Test all pairs of parameters (slow)'.

- 'Stop after one flaw is found per web server (fastest)'

under 'Do not stop after the first flaw is found per web page' is quicker than 'Look for all flaws (slowest)'.

- In the Settings/Advanced menu, try reducing the value for 'Max number of concurrent TCP sessions per host' or 'Max simultaneous checks per host'.

Risk Factor

None

Plugin Information

Published: 2009/06/19, Modified: 2021/01/19

Plugin Output

192.168.100.50 (tcp/80/www)

```
The following tests timed out without finding any flaw :  
- SQL injection (2nd order)  
- injectable parameter  
- SQL injection  
- local file inclusion  
- blind SQL injection (time based)  
- cross-site scripting (comprehensive test)  
- directory traversal  
- web code injection
```

40773 (1) - Web Application Potentially Sensitive CGI Parameter Detection

Synopsis

An application was found that may use CGI parameters to control sensitive information.

Description

According to their names, some CGI parameters may control sensitive data (e.g., ID, privileges, commands, prices, credit card data, etc.). In the course of using an application, these variables may disclose sensitive data or be prone to tampering that could result in privilege escalation. These parameters should be examined to determine what type of data is controlled and if it poses a security risk.

** This plugin only reports information that may be useful for auditors

** or pen-testers, not a real flaw.

Solution

Ensure sensitive data is not disclosed by CGI parameters. In addition, do not use CGI parameters to control access to resources or privileges.

Risk Factor

None

Plugin Information

Published: 2009/08/25, Modified: 2021/01/19

Plugin Output

192.168.100.50 (tcp/80/www)

```
Potentially sensitive parameters for CGI /Admin/register.php :
```

```
password : Possibly a clear or hashed password, vulnerable to sniffing or dictionary attack
```

```
Potentially sensitive parameters for CGI /Admin/login.php :
```

```
password : Possibly a clear or hashed password, vulnerable to sniffing or dictionary attack
```

43111 (1) - HTTP Methods Allowed (per directory)

Synopsis

This plugin determines which HTTP methods are allowed on various CGI directories.

Description

By calling the OPTIONS method, it is possible to determine which HTTP methods are allowed on each directory.

The following HTTP methods are considered insecure:

PUT, DELETE, CONNECT, TRACE, HEAD

Many frameworks and languages treat 'HEAD' as a 'GET' request, albeit one without any body in the response. If a security constraint was set on 'GET' requests such that only 'authenticatedUsers' could access GET requests for a particular servlet or resource, it would be bypassed for the 'HEAD' version. This allowed unauthorized blind submission of any privileged GET request.

As this list may be incomplete, the plugin also tests - if 'Thorough tests' are enabled or 'Enable web applications tests' is set to 'yes'

in the scan policy - various known HTTP methods on each directory and considers them as unsupported if it receives a response code of 400, 403, 405, or 501.

Note that the plugin output is only informational and does not necessarily indicate the presence of any security vulnerabilities.

See Also

<http://www.nessus.org/u?d9c03a9a>

<http://www.nessus.org/u?b019cbdb>

[https://www.owasp.org/index.php/Test_HTTP_Methods_\(OTG-CONFIG-006\)](https://www.owasp.org/index.php/Test_HTTP_Methods_(OTG-CONFIG-006))

Solution

n/a

Risk Factor

None

Plugin Information

Published: 2009/12/10, Modified: 2022/04/11

Plugin Output

192.168.100.50 (tcp/80/www)

Based on the response to an OPTIONS request :

- HTTP methods GET HEAD OPTIONS POST are allowed on :

```
/Admin/assets
/Admin/assets/css
/Admin/assets/css/pages
/Admin/assets/css/widgets
/Admin/assets/images
/Admin/assets/images/logo
/Admin/assets/js
/Admin/assets/js/extensions
/Admin/assets/js/include
/Admin/assets/js/pages
/Admin/assets/plugin
/Admin/assets/plugin/iziToast-master
/Admin/assets/plugin/iziToast-master/dist
/Admin/assets/plugin/iziToast-master/src
/Admin/assets/plugin/iziToast-master/types
```

Based on tests of each method :

- HTTP methods GET HEAD OPTIONS POST are allowed on :

```
/
/Admin
/Admin/assets
```

48204 (1) - Apache HTTP Server Version

Synopsis

It is possible to obtain the version number of the remote Apache HTTP server.

Description

The remote host is running the Apache HTTP Server, an open source web server. It was possible to read the version number from the banner.

See Also

<https://httpd.apache.org/>

Solution

n/a

Risk Factor

None

References

XREF IAVT:0001-T-0030

XREF IAVT:0001-T-0530

Plugin Information

Published: 2010/07/30, Modified: 2026/01/22

Plugin Output

192.168.100.50 (tcp/80/www)

```
URL      : http://192.168.100.50/
Version  : 2.4.58
Source   : Server: Apache/2.4.58 (Ubuntu)
backported : 1
os       : Ubuntu
```

49704 (1) - External URLs

Synopsis

Links to external sites were gathered.

Description

Nessus gathered HREF links to external sites by crawling the remote web server.

Solution

n/a

Risk Factor

None

Plugin Information

Published: 2010/10/04, Modified: 2011/08/19

Plugin Output

192.168.100.50 (tcp/80/www)

```
34 external URLs were gathered on this web server :
URL... - Seen on...

http://amitjakhu.com - /Admin/assets/vendors/dripicons/icons-reference.html
http://creativecommons.org/licenses/by/3.0/ - /fonts/flaticon/font/flaticon.html
http://creativecommons.org/licenses/by/4.0/ - /Admin/assets/vendors/dripicons/icons-reference.html
http://designerfuel.tumblr.com/post/141385060889/dripicons-v2-free-iconset-available-formats - /
Admin/assets/vendors/dripicons/icons-reference.html
http://fontastic.me/ - /Admin/assets/vendors/dripicons/icons-reference.html
http://fonts.googleapis.com/css?family=Dosis:400,500,700 - /Admin/assets/vendors/dripicons/icons-
reference.html
http://fonts.googleapis.com/css?family=Varela+Round - /fonts/flaticon/font/flaticon.html
http://scripts.sil.org/cms/scripts/page.php?site_id=nrsi&id=OFL - /Admin/assets/vendors/dripicons/
icons-reference.html
http://thierry.schmit.free.fr/spip/spip.php?article15 - /Admin/assets/plugin/pdf/FAQ.htm
http://www.fpdf.org/?go=script&id=76 - /Admin/assets/plugin/pdf/FAQ.htm
http://www.fpdf.org/?go=script&id=92 - /Admin/assets/plugin/pdf/FAQ.htm
http://www.fpdf.org/makefont/ - /Admin/assets/plugin/pdf/tutorial/tuto7.htm
http://www.lcdf.org/~eddielwo/type/#tlutils - /Admin/assets/plugin/pdf/tutorial/tuto7.htm
https://cdn.jsdelivrivr.net/npm/simple-datatables@latest/dist/style.css - /
https://cdn.jsdelivrivr.net/npm/summernote@0.8.18/dist/summernote-lite.min.css - /
https://fonts.google.com/specimen/Ceviche+One - /Admin/assets/plugin/pdf/tutorial/tuto7.htm
https://fonts.googleapis.com - /
https://fonts.googleapis.com/css2?family=Josefin+Sans&display=swap - /
https://fonts.googleapis.com/css2?family=Nunito:wght@300;400;600;700;800&display=swap - /Admin/
login.php
https://fonts.googleapis.com/css2?family=Rubik:wght@300&display=swap - /
https://fonts.googleapis.com/css?family=Poppins:200,300,400,700,900|Display+Playfair:200,300,400,700
- /
```


https://fonts.gstatic.com - /
[...]

50344 (1) - Missing or Permissive Content-Security-Policy frame-ancestors HTTP Response Header

Synopsis

The remote web server does not take steps to mitigate a class of web application vulnerabilities.

Description

The remote web server in some responses sets a permissive Content-Security-Policy (CSP) frame-ancestors response header or does not set one at all.

The CSP frame-ancestors header has been proposed by the W3C Web Application Security Working Group as a way to mitigate cross-site scripting and clickjacking attacks.

See Also

<http://www.nessus.org/u?55aa8f57>

<http://www.nessus.org/u?07cc2a06>

<https://content-security-policy.com/>

<https://www.w3.org/TR/CSP2/>

Solution

Set a non-permissive Content-Security-Policy frame-ancestors header for all requested resources.

Risk Factor

None

Plugin Information

Published: 2010/10/26, Modified: 2021/01/19

Plugin Output

192.168.100.50 (tcp/80/www)

The following pages do not set a Content-Security-Policy frame-ancestors response header or set a permissive policy:

- <http://192.168.100.50/>
- <http://192.168.100.50/Admin/assets/>
- <http://192.168.100.50/Admin/assets/css/>
- <http://192.168.100.50/Admin/assets/css/pages/>
- <http://192.168.100.50/Admin/assets/css/widgets/>
- <http://192.168.100.50/Admin/assets/images/>
- <http://192.168.100.50/Admin/assets/images/logo/>
- <http://192.168.100.50/Admin/assets/js/>
- <http://192.168.100.50/Admin/assets/js/extensions/>

```
- http://192.168.100.50/Admin/assets/js/include/
- http://192.168.100.50/Admin/assets/js/pages/
- http://192.168.100.50/Admin/assets/plugin/
- http://192.168.100.50/Admin/assets/plugin/iziToast-master/
- http://192.168.100.50/Admin/assets/plugin/iziToast-master/dist/
- http://192.168.100.50/Admin/assets/plugin/iziToast-master/src/
- http://192.168.100.50/Admin/assets/plugin/iziToast-master/types/
- http://192.168.100.50/Admin/assets/plugin/pdf/
- http://192.168.100.50/Admin/assets/plugin/pdf/FAQ.htm
- http://192.168.100.50/Admin/assets/plugin/pdf/changelog.htm
- http://192.168.100.50/Admin/assets/plugin/pdf/doc/
- http://192.168.100.50/Admin/assets/plugin/pdf/doc/__construct.htm
- http://192.168.100.50/Admin/assets/plugin/pdf/doc/acceptpagebreak.htm
- http://192.168.100.50/Admin/assets/plugin/pdf/doc/addfont.htm
- http://192.168.100.50/Admin/assets/plugin/pdf/doc/addlink.htm
- http://192.168.100.50/Admin/assets/plugin/pdf/doc/addpage.htm
- http://192.168.100.50/Admin/assets/plugin/pdf/doc/aliasnbpages.htm
- http://192.168.100.50/Admin/assets/plugin/pdf/doc/cell.htm
- http://192.168.100.50/Admin/assets/plugin/pdf/doc/close.htm
- http://192.168.100.50/Admin/assets/plugin/pdf/doc/error.htm
- http://192.168.100.50/Admin/assets/plugin/pdf/doc/footer.htm
- http://192.168.100.50/Admin/assets/plugin/pdf/doc/getpageheight.htm
- http://192.168.100.50/Admin/assets/plugin/pdf/doc/getpagewidth.htm
- http://192.168.100.50/Admin/assets/plugin/pdf/doc/getstringwidth [...]
```

50345 (1) - Missing or Permissive X-Frame-Options HTTP Response Header

Synopsis

The remote web server does not take steps to mitigate a class of web application vulnerabilities.

Description

The remote web server in some responses sets a permissive X-Frame-Options response header or does not set one at all.

The X-Frame-Options header has been proposed by Microsoft as a way to mitigate clickjacking attacks and is currently supported by all major browser vendors

See Also

<https://en.wikipedia.org/wiki/Clickjacking>

<http://www.nessus.org/u?399b1f56>

Solution

Set a properly configured X-Frame-Options header for all requested resources.

Risk Factor

None

Plugin Information

Published: 2010/10/26, Modified: 2021/01/19

Plugin Output

192.168.100.50 (tcp/80/www)

The following pages do not set a X-Frame-Options response header or set a permissive policy:

- http://192.168.100.50/
- http://192.168.100.50/Admin/assets/
- http://192.168.100.50/Admin/assets/css/
- http://192.168.100.50/Admin/assets/css/pages/
- http://192.168.100.50/Admin/assets/css/widgets/
- http://192.168.100.50/Admin/assets/images/
- http://192.168.100.50/Admin/assets/images/logo/
- http://192.168.100.50/Admin/assets/js/
- http://192.168.100.50/Admin/assets/js/extensions/
- http://192.168.100.50/Admin/assets/js/include/
- http://192.168.100.50/Admin/assets/js/pages/
- http://192.168.100.50/Admin/assets/plugin/
- http://192.168.100.50/Admin/assets/plugin/iziToast-master/
- http://192.168.100.50/Admin/assets/plugin/iziToast-master/dist/
- http://192.168.100.50/Admin/assets/plugin/iziToast-master/src/

```
- http://192.168.100.50/Admin/assets/plugin/iziToast-master/types/
- http://192.168.100.50/Admin/assets/plugin/pdf/
- http://192.168.100.50/Admin/assets/plugin/pdf/FAQ.htm
- http://192.168.100.50/Admin/assets/plugin/pdf/changelog.htm
- http://192.168.100.50/Admin/assets/plugin/pdf/doc/
- http://192.168.100.50/Admin/assets/plugin/pdf/doc/__construct.htm
- http://192.168.100.50/Admin/assets/plugin/pdf/doc/acceptpagebreak.htm
- http://192.168.100.50/Admin/assets/plugin/pdf/doc/addfont.htm
- http://192.168.100.50/Admin/assets/plugin/pdf/doc/addlink.htm
- http://192.168.100.50/Admin/assets/plugin/pdf/doc/addpage.htm
- http://192.168.100.50/Admin/assets/plugin/pdf/doc/aliasnbpages.htm
- http://192.168.100.50/Admin/assets/plugin/pdf/doc/cell.htm
- http://192.168.100.50/Admin/assets/plugin/pdf/doc/close.htm
- http://192.168.100.50/Admin/assets/plugin/pdf/doc/error.htm
- http://192.168.100.50/Admin/assets/plugin/pdf/doc/footer.htm
- http://192.168.100.50/Admin/assets/plugin/pdf/doc/getpageheight.htm
- http://192.168.100.50/Admin/assets/plugin/pdf/doc/getpagewidth.htm
- http://192.168.100.50/Admin/assets/plugin/pdf/doc/getstringwidth.htm
- http://192.168 [...]
```

66334 (1) - Patch Report

Synopsis

The remote host is missing several patches.

Description

The remote host is missing one or more security patches. This plugin lists the newest version of each patch to install to make sure the remote host is up-to-date.

Note: Because the 'Show missing patches that have been superseded' setting in your scan policy depends on this plugin, it will always run and cannot be disabled.

Solution

Install the patches listed below.

Risk Factor

None

Plugin Information

Published: 2013/07/08, Modified: 2026/04/16

Plugin Output

192.168.100.50 (tcp/0)

```
. You need to take the following action :  
[ JQuery 1.2 < 3.5.0 Multiple XSS (136929) ]  
+ Action to take : Upgrade to JQuery version 3.5.0 or later.
```

72771 (1) - Web Accessible Backups

Synopsis

The remote web server hosts web-accessible backups or archives.

Description

The remote web server is hosting web-accessible archive files that may contain backups or sensitive data.

Solution

Review each of the files and ensure they are in compliance with your security policy.

Risk Factor

None

Plugin Information

Published: 2014/03/03, Modified: 2022/04/11

Plugin Output

192.168.100.50 (tcp/80/www)

```
Nessus was able to identify the following archive file on the
remote web server :
```

```
ZIP Archive :
  http://192.168.100.50/Admin/assets/plugin/pdf/fpdf184.zip
```

85601 (1) - Web Application Cookies Not Marked HttpOnly

Synopsis

HTTP session cookies might be vulnerable to cross-site scripting attacks.

Description

The remote web application sets various cookies throughout a user's unauthenticated and authenticated session. However, one or more of those cookies are not marked 'HttpOnly', meaning that a malicious client-side script, such as JavaScript, could read them. The HttpOnly flag is a security mechanism to protect against cross-site scripting attacks, which was proposed by Microsoft and initially implemented in Internet Explorer. All modern browsers now support it.

Note that this plugin detects all general cookies missing the HttpOnly cookie flag, whereas plugin 48432 (Web Application Session Cookies Not Marked HttpOnly) will only detect session cookies from an authenticated session missing the HttpOnly cookie flag.

See Also

<https://www.owasp.org/index.php/HttpOnly>

Solution

Each cookie should be carefully reviewed to determine if it contains sensitive data or is relied upon for a security decision.

If possible, add the 'HttpOnly' attribute to all session cookies and any cookies containing sensitive data.

Risk Factor

None

References

XREF	CWE:20
XREF	CWE:74
XREF	CWE:79
XREF	CWE:442
XREF	CWE:629
XREF	CWE:711
XREF	CWE:712
XREF	CWE:722
XREF	CWE:725
XREF	CWE:750
XREF	CWE:751
XREF	CWE:800

XREF	CWE:801
XREF	CWE:809
XREF	CWE:811
XREF	CWE:864
XREF	CWE:900
XREF	CWE:928
XREF	CWE:931
XREF	CWE:990

Plugin Information

Published: 2015/08/24, Modified: 2015/08/24

Plugin Output

192.168.100.50 (tcp/80/www)

The following cookie does not set the HttpOnly cookie flag :

Name : PHPSESSID
Path : /
Value : t1b7nsa11injk6rs9l619lu1s3
Domain : 192.168.100.50
Version :
Expires :
Comment :
Secure : false
Httponly : false
Port :

85602 (1) - Web Application Cookies Not Marked Secure

Synopsis

HTTP session cookies might be transmitted in cleartext.

Description

The remote web application sets various cookies throughout a user's unauthenticated and authenticated session. However, there are instances where the application is running over unencrypted HTTP or the cookies are not marked 'secure', meaning the browser could send them back over an unencrypted link under certain circumstances. As a result, it may be possible for a remote attacker to intercept these cookies.

Note that this plugin detects all general cookies missing the 'secure'

cookie flag, whereas plugin 49218 (Web Application Session Cookies Not Marked Secure) will only detect session cookies from an authenticated session missing the secure cookie flag.

See Also

<https://www.owasp.org/index.php/SecureFlag>

Solution

Each cookie should be carefully reviewed to determine if it contains sensitive data or is relied upon for a security decision.

If possible, ensure all communication occurs over an encrypted channel and add the 'secure' attribute to all session cookies or any cookies containing sensitive data.

Risk Factor

None

References

XREF	CWE:522
XREF	CWE:718
XREF	CWE:724
XREF	CWE:928
XREF	CWE:930

Plugin Information

Published: 2015/08/24, Modified: 2015/08/24

Plugin Output

192.168.100.50 (tcp/80/www)

The following cookie does not set the secure cookie flag :

Name : PHPSESSID
Path : /
Value : t1b7nsa11injk6rs9l619lu1s3
Domain : 192.168.100.50
Version :
Expires :
Comment :
Secure : false
Httponly : false
Port :

91815 (1) - Web Application Sitemap

Synopsis

The remote web server hosts linkable content that can be crawled by Nessus.

Description

The remote web server contains linkable content that can be used to gather information about a target.

See Also

<http://www.nessus.org/u?5496c8d9>

Solution

n/a

Risk Factor

None

Plugin Information

Published: 2016/06/24, Modified: 2016/06/24

Plugin Output

192.168.100.50 (tcp/80/www)

The following sitemap was created from crawling linkable content on the target host :

- <http://192.168.100.50/>
- <http://192.168.100.50/Admin/assets/>
- <http://192.168.100.50/Admin/assets/css/>
- <http://192.168.100.50/Admin/assets/css/app.css>
- <http://192.168.100.50/Admin/assets/css/bootstrap.css>
- <http://192.168.100.50/Admin/assets/css/pages/>
- <http://192.168.100.50/Admin/assets/css/pages/auth.css>
- <http://192.168.100.50/Admin/assets/css/pages/chat.css>
- <http://192.168.100.50/Admin/assets/css/pages/dripicons.css>
- <http://192.168.100.50/Admin/assets/css/pages/email.css>
- <http://192.168.100.50/Admin/assets/css/pages/error.css>
- <http://192.168.100.50/Admin/assets/css/widgets/>
- <http://192.168.100.50/Admin/assets/css/widgets/chat.css>
- <http://192.168.100.50/Admin/assets/css/widgets/todo.css>
- <http://192.168.100.50/Admin/assets/images/>
- <http://192.168.100.50/Admin/assets/images/logo/>
- <http://192.168.100.50/Admin/assets/images/logo/logo.png>
- <http://192.168.100.50/Admin/assets/js/>
- <http://192.168.100.50/Admin/assets/js/bootstrap.bundle.min.js>
- <http://192.168.100.50/Admin/assets/js/bootstrap.min.js>
- <http://192.168.100.50/Admin/assets/js/bootstrap.min.js.map>

- <http://192.168.100.50/Admin/assets/js/extensions/>
- <http://192.168.100.50/Admin/assets/js/extensions/rater-js.js>
- <http://192.168.100.50/Admin/assets/js/extensions/sweetalert2.js>
- <http://192.168.100.50/Admin/assets/js/extensions/toastify.js>
- <http://192.168.100.50/Admin/assets/js/include/>
- <http://192.168.100.50/Admin/assets/js/include/add.js>
- <http://192.168.100.50/Admin/assets/js/include/alerts.js>
- <http://192.168.100.50/Admin/assets/js/include/delete.js>
- <http://192.168.100.50/Admin/assets/js/include/homejs.js>
- <http://192.168.100.50/Admin/assets/js/include/main.js>
- <http://192.168.100.50/Admin/assets/js/include/upload.js>
- <http://192.168.100.50/Admin/assets/js/include/validation.js>
- <http://192.168.100.50/Admin/assets/js/main.js>
- <http://192.168.100.50/Admin/assets/js/pages/>
- <http://1> [...]

106658 (1) - JQuery Detection

Synopsis

The web server on the remote host uses JQuery.

Description

Nessus was able to detect JQuery on the remote host.

See Also

<https://jquery.com/>

Solution

n/a

Risk Factor

None

Plugin Information

Published: 2018/02/07, Modified: 2024/02/08

Plugin Output

192.168.100.50 (tcp/80/www)

```
URL      : http://192.168.100.50/js/jquery-3.3.1.min.js
Version  : 3.3.1
```

Error(s) occurred during detection. Please enable plugin debugging for more information.

156439 (1) - jQuery UI Detection

Synopsis

The web server on the remote host uses jQuery UI.

Description

The web server on the remote host uses jQuery UI.

See Also

<https://releases.jquery.com/ui/>

Solution

n/a

Risk Factor

None

Plugin Information

Published: 2021/12/31, Modified: 2023/05/24

Plugin Output

192.168.100.50 (tcp/80/www)

```
URL      : http://192.168.100.50/js/jquery-ui.js
Version  : 1.12.1
```